Manuscrito científico técnico 01

Identidad federada segura e interoperabilidad Prime–Quantum Coach | Propuesta de implementación v1.0

Resumen y pregunta de investigación

¿Cómo construir identidad federada consistente entre GoToGym Prime y Quantum Coach sin fusionar bases de datos, exponer identificadores al modelo ni alterar usuarios preexistentes? Se propone un puente de identidad de confianza entre servidores con Microsoft Entra External ID, resolución determinista de cuentas y degradación segura al modo visitante.

1. Estado de partida y límites de evidencia

Repositorios examinados en la conversación: gotogymsaas/login, gotogymsaas/GoToGtymPrime y gotogymsaas/appdesplegada. Prime diferencia shop_u_ (sesión autenticada) de shop_v_ (visitante), pero ese sujeto comercial no es una llave federada suficiente. El diseño COMMERCE previo impide enviar PII y consultar directamente User/coach_state. La presencia del endpoint /api/commerce/agent/message/ en la rama principal de appdesplegada requiere confirmación y recuperación. Estas son observaciones de inspección de código, no pruebas de producción.

2. Hipótesis y requisitos verificables

H1: issuer + oid verificados permiten enlazar cuentas entre aplicaciones sin depender de email ni del claim sub. H2: un intercambio firmado entre servicios reduce la exposición frente al envío de tokens al navegador o al LLM. H3: conservar el modo anónimo evita regresiones de conversión. Requisitos: no cambiar contraseñas, planes, suscripciones, permisos ni historiales; no crear usuarios por inferencia de correo; idempotencia, revocación y trazabilidad.

3. Modelo de identidad y vínculo

```
K = (issuer, oid)
resolve(K) -> {linked_user_id | NOT_LINKED | CONFLICT}
shop_subject = HMAC(k_shop, "commerce:v1:" || K)
No utilizar email como clave primaria de vinculación.
```

El identificador federado debe validarse contra issuer, audiencia, firma JWKS, nonce/state, expiración y flujo OIDC apropiado. Prime no debe aceptar un oid enviado por el cliente como prueba de autenticación. Para cuentas antiguas, la vinculación se hace mediante sesión preexistente validada y flujo explícito de enlace, con restricción única por proveedor/issuer/oid y controles de conflicto.

4. Protocolo entre servicios

```
Prime server -- POST signed --> Coach commerce gateway
{request_id, conversation_id, visitor.subject, authenticated,
 identity_ref?, consent_version?, evidence, page, cart, timestamp}
Coach: verify signature + timestamp + replay nonce
      -> resolve identity_ref server-side
      -> allowlisted context -> commerce orchestrator
```

identity_ref es una referencia opaca, de corta vida y limitada a audiencia COMMERCE; alternativamente un token de intercambio firmado de uso único, sin PII. Firmar cuerpo canónico, validar ventana temporal, rotar claves y usar HTTPS. El servidor de Coach nunca confiará en authenticated=true sin la prueba criptográfica correspondiente.

5. Propuesta matemática de seguridad

Definimos riesgo de exposición R = Σ_i s_i · p_i · a_i, donde s_i es sensibilidad del atributo, p_i probabilidad estimada de divulgación y a_i superficie de acceso. El objetivo de diseño es minimizar R sujeto a utilidad comercial U ≥ U_min y latencia L ≤ L_max. La función objetivo J = U − λR − μL es una formulación de ingeniería propuesta, no una ley física ni un resultado QAF validado.

6. Algoritmo de resolución y pseudocódigo

```
def resolve_commerce_identity(assertion, links):
    claims = verify_signed_assertion(assertion, audience="commerce")
    if claims is None: return Anonymous()
    key = (claims["issuer"], claims["oid"])
    matches = links.lookup_exact(key)
    if len(matches) != 1: return UnlinkedOrConflict()
    return LinkedUser(matches[0].user_id)
```

Nunca convertir errores de firma, enlace ausente o conflictos en coincidencias por nombre/correo. Registrar únicamente códigos de error, correlación y hashes no reversibles.

7. Migración y compatibilidad

Etapa 0: inventario de clientes OIDC, redirect URI, modelo ExternalIdentityLink y esquema actual. Etapa 1: pruebas unitarias y contrato v2 optativo. Etapa 2: shadow mode sin exponer contexto. Etapa 3: piloto con usuarios vinculados y consentimiento. Etapa 4: despliegue gradual con feature flag y rollback a contrato v1 anónimo. Mantener la autenticación antigua durante la transición.

8. Pruebas de aceptación y amenazas

Probar: dos usuarios distintos con mismo email no se unen; oid falso o firma inválida se rechaza; token expirado o repetido se rechaza; sesión anónima continúa; logout invalida referencia; vinculación duplicada bloqueada; servicio caído muestra fallback sin filtrar datos; usuario sin consentimiento no recibe personalización. Realizar revisión de CSRF, SSRF, BOLA/IDOR, replay y filtración en logs.

9. Plan de implementación por repositorio

login: especificar claims y reglas de enlace. Prime: resolver sesión y emitir identity_ref efímera desde backend; extender contrato sin PII. appdesplegada: recuperar gateway COMMERCE, validar aserción, resolver ExternalIdentityLink y aislar contexto. No ejecutar migraciones destructivas ni fusionar ramas sin pruebas y revisión.

10. Criterios de éxito y referencias internas

Cobertura objetivo: 100% de casos de seguridad obligatorios; cero lecturas de perfiles ajenos; cero regresiones de login; compatibilidad de visitantes; trazabilidad por request_id. Referencias internas: archivos de Prime gotogym/vendedor/paquete.py, views.py, contrato.py; integración OIDC en login; modelo ExternalIdentityLink en appdesplegada. Los umbrales operativos finales deben medirse en staging.